

Postman Token Auth Proof

Table of Contents

Postman Token Authentication Proof

Postman Token Authentication Proof

The committed Postman environment is a sanitized local template. Fill

`login_email`, `login_password`, resource IDs, and tokens only in a private local copy.

Bearer tokens are returned in the JSON login response only in automated tests, or in an explicitly enabled local development run (`EXPOSE_SESSION_TOKEN=true`). Staging and production refuse this flag and use the Secure, HttpOnly `alc_session` cookie.

For a local API-client proof:

1. Start the API in development with a persistent local database and explicitly enable response-token exposure.
2. `POST {{base_url}}/auth/login` using a locally provisioned account.
3. Save `data.sessionToken` as the secret `session_token` variable.
4. Verify `GET {{base_url}}/auth/me` returns `200` with `Authorization: Bearer {{session_token}}`.
5. `POST {{base_url}}/auth/logout` with the same bearer token.
6. Verify the same token then returns `401`.

Changing a password revokes every prior session and returns a newly rotated token only under the local/test exposure rule. The old token must return `401`.

The legacy Postman credential bypass and mock Google tokens are test-only.
Configuration validation aborts startup if either is requested outside

`NODE_ENV=test` .